IMCC LMS PORTAL – SECURITY AUDIT DOCUMENT

1. Rules of Engagement

This document explains what auditors are allowed to test and what they must avoid during the security audit.

Auditors are allowed to test:

- Login and authentication pages, including Google SSO, Super Admin login, and demo accounts.
- Student, Instructor, Dean, and Super Admin dashboards.
- Classes, class codes, joining, unenrolling, and class management.
- Lessons, assignments, quizzes, activities, file uploads, submissions, and grading.
- Class Records, exports, calendar, resources, notifications, and the AI chatbot.
- The system API (/api/*) for safe authentication, authorization, IDOR, and input-validation testing.
- The project source code in the provided audit version.

Auditors must not:

- Access real faculty or student accounts or personal data.
- Access or expose .env files, passwords, API keys, database credentials, or other secrets.
- Modify Google Cloud, Supabase/PostgreSQL, Flowise, or ngrok administration settings.
- Delete shared seed data or perform destructive testing.
- Perform denial-of-service, load testing, or brute-force attacks against real accounts.

If something looks broken:

Take a screenshot and record the page, time, account/role used, and what happened. Contact the project representative before treating the issue as a security vulnerability.

Primary Contact: [Name / Email]

Backup Contact: [Name / Email]

Known bugs or limitations that should not be treated as security issues:

- Some files download instead of previewing.
- Older classes may show “Instructor not set.”
- There is no forgot-password feature.
- The AI chatbot may not work when the Flowise service is offline.
- The public ngrok URL may change after restarting the tunnel.
- Demo accounts intentionally bypass real Google sign-in.

2. Basic Information

Project Name: IMCC LMS Portal (Bright LMS)

Description: A web-based Learning Management System for Iligan Medical Center College. It manages classes, learning materials, submissions, grades, class records, calendar events, resources, notifications, and an AI chatbot.

Current Stage: Working prototype – runnable end-to-end.

Tech Stack:

- Frontend: HTML5, CSS3, JavaScript
- Backend: Node.js and Express
- Database: PostgreSQL
- Authentication: Google SSO and Super Admin login
- AI: Flowise chatbot
- Deployment: Docker and ngrok

Major Features:

- Login and role-based dashboards
- Class management
- Lessons, assignments, quizzes, and activities
- File uploads and student submissions
- Grading and feedback
- Class Records and exports
- Calendar and Resources/Study Library
- Notifications
- Super Admin panel
- AI chatbot

User Roles:

Super Admin: Manages institutional accounts and user roles.

Dean: Creates classes, assigns instructors, manages class work, grades, and exports records.

Instructor: Manages assigned classes, learning materials, submissions, grades, events, and resources.

Student: Joins classes, views materials, submits work, checks grades, and uses resources and the chatbot.

3. Access Ready to Go

Auditors will be provided with the following:

- Public audit link: [Audit URL]
- Locked repository: https://github.com/codedbyjayr/imcc-lms (audit-v1.0)
- Super Admin test account: admin@imcc.edu.ph / [Password]
- Demo accounts for Dean, Instructor, and Student roles.

Only the provided test accounts should be used during the audit. Real institutional accounts must not be tested.

4. Locked Snapshot

The project will be treated as locked on the agreed audit date. Auditors will review this exact version.

Snapshot Tag: audit-v1.0

Commit Hash: [Hash]

Snapshot Date: [Date]

Docker Build Date: [Date]

Database Seed Date: [Date]

No code, database, or configuration changes should be made during the audit unless approved by the faculty adviser and documented.

5. Know Your Own Project's Security Basics

The project uses Google SSO as the main authentication method. The system accepts @imcc.edu.ph accounts and gets the user's role from the database. The Super Admin also has a separate credential login.

Access is controlled by user roles. Students, Instructors, Deans, and Super Admins have different permissions. For example, Deans can create classes, Instructors can manage class work and grades, and only the Super Admin can access the Super Admin panel.

The system uses parameterized SQL queries to help prevent SQL injection and HTML escaping to reduce XSS risks. File uploads are limited by allowed extensions and a 25 MB size limit.

During the audit, the main security checks should focus on authentication, role permissions, unauthorized access to other users' or classes' data, API access, file uploads, and user input.